



AIRSHIELD

PRIVATE AI CONTROL PLANE

EXECUTIVE • ARCHITECTURE • SECURITY

CEO Technical Briefing

Architecture, trust boundaries, technology, encryption and voice protection

KEEP THE INTELLIGENCE. REMOVE THE IDENTIFIERS.

CAPTURE

PROTECT

AUTHORIZE

PROVE

Contents

Architecture, trust boundaries, technology, encryption and voice protection

1. Executive answer: what AirShield does	3
2. Why it is needed	3
3. Current implemented product versus target platform	4
4. Architectural principle: separate trust from intelligence	4
5. End-to-end text protection path	6
6. Voice capture and protection in detail	6
7. How AirShield determines a real participant and correct speaker	7
8. Technology stack and why each part exists	8
9. Encryption and token-vault logic in detail	8
10. Receipts, evidence and retention	10
11. Policy, destination authorization and RIA integration	10
11A. EgressSeal product layer	11
12. CareShield Assistant walkthrough	12
13. Threats and control intent	12
14. Deployment for Nordic, EU and US clients	13
15. Operational production requirements	13
16. CEO questions and direct answers	14
17. Product opportunities alongside the core	15
18. Recommended phased path	15

1. Executive answer: what AirShield does

AirShield sits between a trusted customer channel and a downstream AI or application. It captures or receives English voice/text, identifies policy-scoped PII, PHI, PCI data and enterprise secrets, transforms sensitive values into masks or controlled tokens, authorizes the destination and creates evidence of the decision. The intended downstream payload contains useful meaning plus protected references—not raw identity.

Its core visual proof is simple: the person sees the raw spoken transcript inside the trust boundary and the protected outbound transcript beside it. AirShield then shows the policy decision and receipt that govern whether egress is permitted.

AirShield is horizontal infrastructure, not a healthcare-only product:

Sector	Typical protected workflow	Examples of sensitive content
Healthcare	Virtual intake, notes, clinician assistance	Patient identity, symptoms, medical record identifiers
Finance	Service calls, support copilots, transaction investigation	PAN, accounts, routing data, identity and authentication data
Insurance	Claims intake, adjuster assistance, document summarization	Claimants, policy numbers, health/financial evidence
BPO / Contact Centers	Agent assist, quality review, summarization	Caller identity, customer records, credentials and payment data
SaaS / Internal Copilots	Search, support, coding and operations assistance	Employee/customer data, source secrets, tickets and internal identifiers

2. Why it is needed

Organizations usually face a false choice: send high-context raw data to an AI service, or remove so much context that the workflow loses value. Network controls, access control and encryption in transit help, but they do not change what an authorized destination can read after delivery. Prompt instructions such as “do not reveal PII” are not a reliable data-loss-prevention boundary.

AirShield changes the control point. It attempts to protect content before the destination receives it, bind the decision to tenant and destination policy, and preserve audit evidence. This supports data minimization, reduces breach blast radius and creates a governed integration point across many AI providers and legacy applications.

The business need is especially strong when:

- raw audio/transcripts contain mixed identity and useful intent;
- the downstream AI does not need to know the person's direct identity;
- regional or contractual requirements restrict where raw data may go;
- contact-center or copilot scale makes manual redaction impossible;
- organizations need reversible references for tightly controlled operational follow-up;
- security teams need proof of what left the boundary, under which policy and why.

AirShield does not make an unsafe workflow safe by itself. It cannot compensate for a detector miss, compromised endpoint, over-privileged KMS identity, application bypass, unsafe tool call or data already sent to an external transcription/model service.

3. Current implemented product versus target platform

Capability	Current repository	Production target / required completion
Responsive UI	Implemented Next.js desktop/tablet/mobile views	Accessibility and customer UX validation
Raw/protected comparison	Implemented for synthetic text and self-hosted voice path	Representative end-to-end quality and latency qualification
CareShield Assistant	Implemented protected virtual-intake and demo reservation UI	Real RIA connector, action broker, clinician directory and booking system integrations
Text protection	Development local detector plus Python production-shaped path	Evaluated detector ensemble, operational monitoring and customer rules
Voice ASR	Self-hosted <code>faster-whisper</code> adapter	Evaluated models, approved codecs/hardware, scaling and failover
Speaker continuity	Optional <code>pyannote.audio</code> tracks	Customer-specific channel binding and quality thresholds
Person authentication	Host OIDC/SSO/OTP/IVR design and gateway validation	Customer identity integration and isolated-channel proof
Encrypted token vault	AES-256-GCM mappings and key-provider abstractions	Real managed KMS/HSM custody, versioned crypto metadata, rotation/recovery testing
Reidentification	API-level requester/approver workflow	Infrastructure-level separation of duties and insider-risk controls
Receipts/evidence	Signed receipt and tenant chain design	Independently administered immutable anchoring and verification operations
RIA/AI integration	Destination-aware protection and demo preview	Dedicated RIA connector, token-aware action broker, complete output/TTS DLP
EgressSeal™	Ed25519-signed development seal bound to protected digest, destination, risk, receipt, expiry and action	Externally trusted KMS/HSM signer and authoritative upstream-receipt verifier
Destination Switch	Interactive route rebinding and recalculation across private, managed, research and public routes	Customer policy registry, live destination identity, revocation and network enforcement
ContextFence™	Explainable cumulative-risk meter for linkage/mosaic risk after masking	Evaluated sector model, conversation memory, threshold governance and monitoring
SafeAction™	Seal-gated synthetic connector with token-only broker path and signed action receipt	Separately deployed action broker and real least-privilege connectors
Deployment	Azure-private and Kubernetes/OpenBao references	Subscription/cluster validation, quotas, policy, DR and independent review

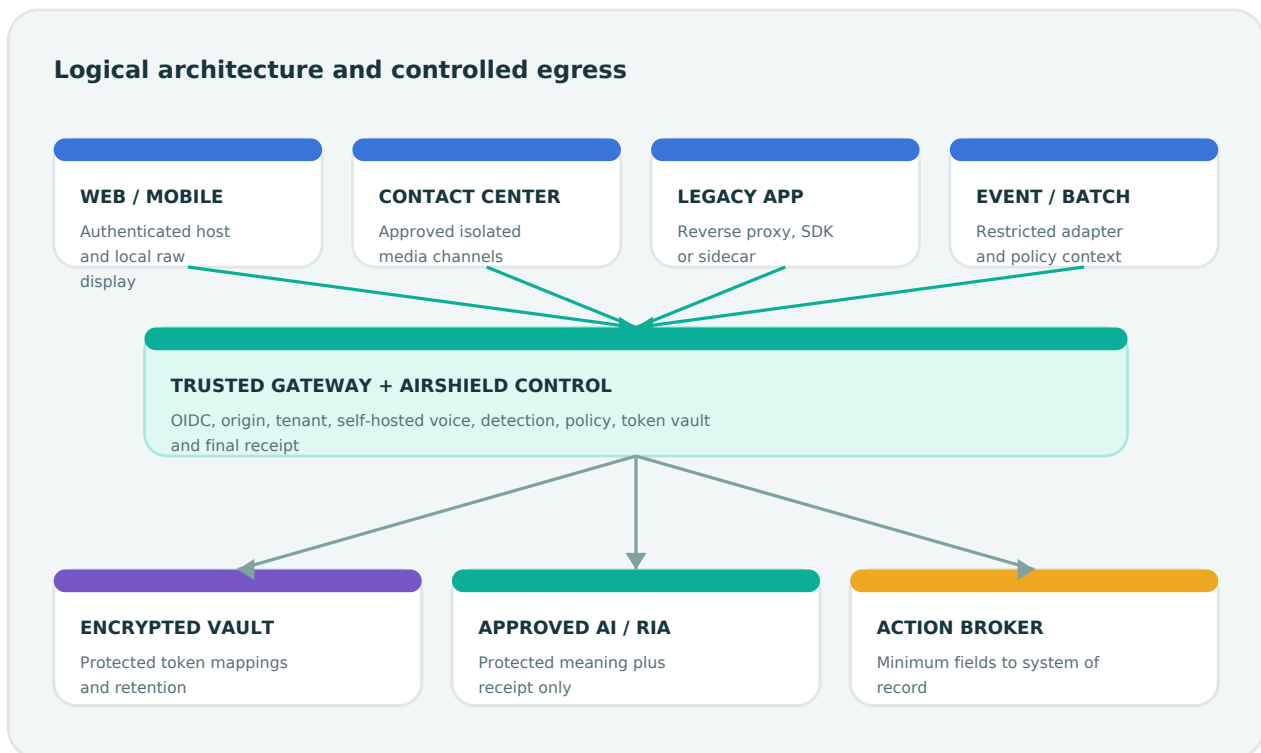
The CareShield appointment is intentionally synthetic. No autonomous diagnosis, clinical record or real reservation occurs.

4. Architectural principle: separate trust from intelligence

AirShield™ separates four concerns that are often incorrectly combined:

- 1 Who is participating?** The trusted host authenticates the person.
- 2 Who is speaking now?** Local diarization tracks voice continuity but does not prove identity.
- 3 What content is sensitive?** Detectors classify policy-relevant entities.

- 4 **May this destination receive this protected payload?** The control plane applies tenant and destination policy and records the decision.



Trust boundaries

Boundary	May contain raw data?	Primary controls
User device / trusted host UI	Yes, transiently	Host authentication, secure browser context, local display and minimized retention
Authenticated gateway	Audio in transit	OIDC, exact origin/tenant, protocol state, rate/size/session limits, private edge routing
Self-hosted voice edge	Yes, transient audio/transcript	Private network, pinned models, bounded memory/session, no paid STT egress
Python control plane	Yes, only to protect/tokenize	Workload identity, tenant policy, detector, vault, evidence and fail-closed decisions
Token vault / database	Encrypted mappings only	Per-record AEAD, wrapped keys, tenant predicates, retention/deletion
Approved AI / RIA	Protected content only	Destination allowlist, receipt, token-aware connector and action policy
Booking/EHR/CRM systems	Only minimum authorized values	Trusted action broker, scoped service identity, field-level release and audit

Raw data protection depends on deployment discipline. If a host application logs request bodies, bypasses the gateway, forwards audio to a vendor STT service or duplicates raw transcript into analytics, AirShield cannot retroactively remove that exposure.

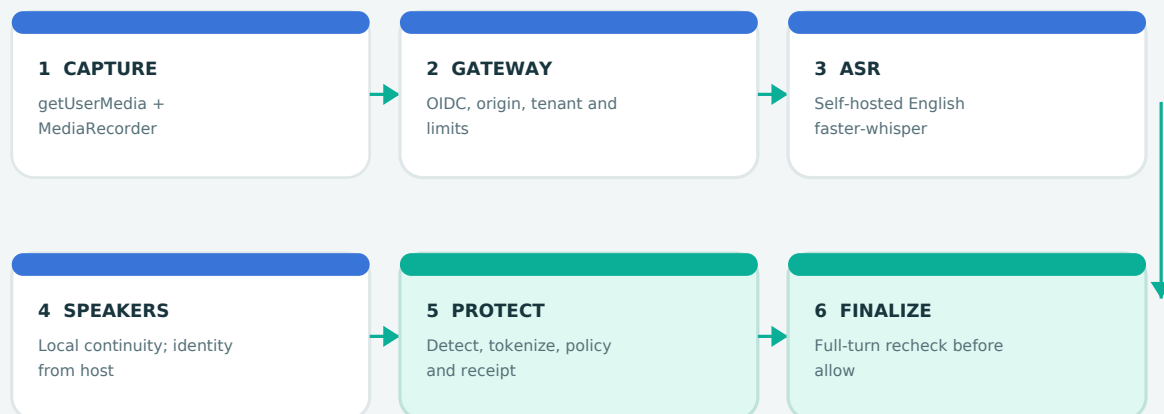
5. End-to-end text protection path

- 1 The authenticated host creates a tenant-scoped session with a selected policy and language.
- 2 The user enters text in the trusted UI or host application.
- 3 The host sends it to a server-side AirShield adapter; browser-supplied bearer credentials are not forwarded as workload identity.
- 4 The control plane validates workload identity, tenant binding, permission, session, policy and destination.
- 5 Deterministic and contextual detectors identify sensitive spans.
- 6 Policy chooses mask, redact, tokenize, block or review behavior by entity and destination.
- 7 Reversible entities receive unrelated tokens; token-to-raw mappings are encrypted in the vault.
- 8 The protected text is assembled without overlapping-span corruption.
- 9 A decision and metadata-only receipt are generated.
- 10 Only an allowed protected payload is sent to the approved destination.
- 11 The response must pass output policy before display, speech synthesis or a tool/action call.

In development-only UI mode, a small local deterministic detector demonstrates the pattern and labels its receipt `demo_unsigned`. Production mode is designed to return a denial/error when the Python control plane is absent rather than silently using that fallback.

6. Voice capture and protection in detail

Voice path: interim is provisional; final allow governs egress



Browser capture

- 1 The user selects microphone capture.
- 2 `getUserMedia` requests a single audio track; no browser/vendor speech recognition API is used.
- 3 The browser opens the configured WebSocket endpoint and sends `session.start` with policy, language and bounded session context.
- 4 `MediaRecorder` emits short binary audio chunks. The browser forwards those chunks; it does not treat them as egress-safe data.
- 5 Stop sends `session.end`, releases media tracks and waits for finalization.

Authenticated gateway

The production browser connects to the gateway, not directly to the private edge. The gateway validates the host-issued OIDC cookie or bearer token, signature, issuer, audience, expiry, tenant and roles/scopes. It also checks exact `Origin`, protocol state, message type, frame/body size, rate, concurrent connections and session duration.

Client-provided “trusted” headers are discarded. The gateway reconstructs the edge session message and injects its own rotatable private edge credential. It verifies the private edge certificate/CA over WSS. Direct external access to the edge must be denied.

Self-hosted ASR and diarization

The edge uses an English `faster-whisper` model and optional `pyannote.audio` diarization. ASR generates transcript candidates. Diarization generates continuity labels such as `SPEAKER_A`; it answers “same voice track or a different track?” rather than “is this Jordan Lee?”

Models should be preloaded on read-only storage. Production startup should verify an approved release manifest and every artifact hash before loading. Runtime model downloads are inappropriate for a controlled release.

Provisional and final turns

As chunks arrive, the edge may emit `transcript.pair` messages containing local raw text, protected text, entity metadata and speaker track. These interim messages are provisional and `safe_for_egress=false`.

At session end, the edge forces processing of remaining short audio, assembles the full transcript and requests final protection. The complete content is rechecked because sensitive entities can span chunk boundaries or become identifiable only with later context. Only a cryptographically verifiable final `allow` is intended to be egress-eligible. `block`, `review`, missing dependencies, unsigned decisions and timeouts fail closed.

Response and TTS path

The target design must apply policy to the model response before displaying it or sending it to self-hosted text-to-speech. The response filter must catch raw data echoed by a tool, prompt-injection output, unauthorized token resolution and newly generated sensitive data. The current repository does not yet implement a comprehensive dedicated output/TTS DLP gateway.

7. How AirShield determines a real participant and correct speaker

AirShield must not claim that voice similarity or diarization proves a human identity. Correct mapping uses an explicit chain of trust:

- 1 Host authentication:** The customer application authenticates the participant using SSO, OTP, authenticated patient/customer portal, IVR verification, CRM/EHR check-in or another approved control.
- 2 Channel provenance:** The host knows which isolated audio channel belongs to which authenticated subject—for example, separate WebRTC tracks or telephony legs. A mixed room microphone usually cannot provide this assurance.
- 3 Signed binding claim:** Only the trusted host identity issuer creates a short-lived signed claim binding the authenticated subject to the specific session and speaker track/channel.
- 4 Gateway verification:** AirShield verifies issuer, audience, signature, expiry, tenant, session, scope and channel claim. Untrusted browser labels are ignored.
- 5 Privacy-preserving persistence:** The control plane stores a keyed subject digest and issues an unrelated speaker token such as `[SPEAKER_8A91C2]`.
- 6 Diarization continuity:** The local model maintains speaker turns. It may help carry a verified channel binding through a session, but confidence degradation or ambiguity must return the track to unknown.
- 7 Unknown-by-default:** Participants without valid host provenance remain `UNKNOWN`; they are not guessed from names spoken aloud or biometric similarity.

Real-person presence (anti-bot/liveness) is a separate control. Depending on risk, the host may require device binding, step-up authentication, challenge-response, telephony attestation, supervised enrollment or specialist anti-spoof/liveness services. AirShield should consume the resulting assurance level; it should not invent one from transcript content.

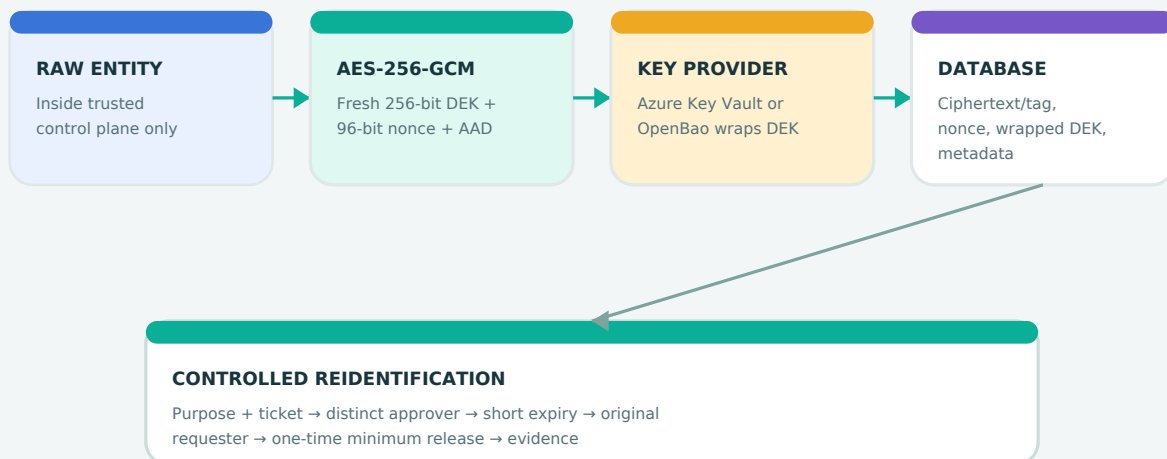
8. Technology stack and why each part exists

Layer	Technology	Role and rationale
Web UI	Next.js 16, React 19, TypeScript	Responsive product, server-only proxy routes and browser capture
UI icons/style	Lucide and repository CSS	Lightweight, offline-compatible, responsive presentation
Control plane	Python 3.12, FastAPI, Pydantic	Policy and security logic with typed API contracts
Persistence	Async SQLAlchemy, Alembic, PostgreSQL	Tenant-scoped records, migrations and operational consistency
Detection	Deterministic recognizers, Presidio, spaCy	High-precision patterns plus contextual entity recognition
Speech	faster-whisper	Company-controlled English ASR without usage-priced STT APIs
Diarization	pyannote.audio, optional	Local speaker-turn continuity; not identity authentication
Gateway	FastAPI/WebSocket service	OIDC, origin/protocol validation and private edge mediation
Cryptography	cryptography AESGCM, Ed25519/provider signing	Authenticated mapping encryption and receipt signatures
Key custody	Azure Key Vault or OpenBao Transit	External wrapping/signing operations and identity-based authorization
Contracts	OpenAPI and AsyncAPI	Integration for Java, .NET, Python, Node.js, Go and other stacks
Deployment	Docker, Kubernetes/Kustomize, Azure Bicep	Repeatable private Azure and portable deployment references
Observability	Structured logs and Prometheus metrics	Metadata-only operations, health, latency and control evidence
Optional AI	Self-hosted Ollama adapter	Demonstration destination after policy allow

Self-hosting avoids per-minute transcription fees and helps data-location control, but it does not eliminate cost. The customer assumes compute, model operations, patching, performance engineering, security monitoring and quality evaluation.

9. Encryption and token-vault logic in detail

Per-record token-vault encryption and controlled resolution



What is encrypted

When policy chooses reversible tokenization, AirShield stores the mapping between an unrelated token and the original sensitive value. The protected transcript contains the token; the raw value belongs only in the encrypted mapping. Decision receipts contain metadata and digests rather than plaintext.

Record encryption sequence

- 1 Generate a random token identifier for the detected entity.
- 2 Generate a fresh 256-bit data-encryption key (DEK) for that mapping.
- 3 Generate a fresh 96-bit nonce for AES-GCM.
- 4 Construct additional authenticated data (AAD) from security context including tenant, session, token and entity type.
- 5 Encrypt the plaintext with AES-256-GCM. The library stores the 16-byte authentication tag appended to ciphertext; this is valid AEAD representation.
- 6 Send the DEK to the configured key provider for wrapping; store only the wrapped DEK with ciphertext, nonce and context metadata.
- 7 Create a keyed HMAC lookup index so equality lookup does not rely on an unsalted hash of low-entropy identifiers.
- 8 Persist through tenant-scoped queries and relationships.

AES-GCM protects confidentiality and integrity of the encrypted mapping at rest. A changed ciphertext, tag, nonce or AAD causes decryption failure. AAD prevents a valid ciphertext from being silently moved into a different tenant/session/token/entity context.

Decryption/reidentification sequence

- 1 Authenticate and authorize the workload.
- 2 Validate tenant and token context.
- 3 Confirm a valid purpose/ticket, distinct approval, expiry and one-time retrieval state.
- 4 Ask the authorized key provider to unwrap the DEK.
- 5 Reconstruct exact AAD and decrypt with AES-GCM.
- 6 Return the minimum value only to the original authorized requester over a protected channel.
- 7 Record metadata-only evidence and consume the one-time retrieval.

Key-provider modes

- **Azure Key Vault:** managed/workload identity calls a customer-controlled vault key for wrap/unwrap or signing operations. Production requires private endpoints/firewall policy, narrow roles, rotation, recovery and audit validation.
- **OpenBao Transit:** a portable Kubernetes profile delegates cryptographic operations to a separately administered Transit engine over authenticated TLS.
- **Local provider:** development/test only. Production startup must reject it.

Current implementation boundaries

The repository implements the core pattern, but it must not be overstated:

- explicit `crypto_version` and `aad_version` fields are not yet present in the mapping schema;
- the current random token suffix has 32 bits and should be expanded for production collision/security margin;
- the configured HMAC index key is application-level rather than a fully realized KMS-held per-tenant key hierarchy;
- KMS wrap and unwrap identity separation is not fully enforced across production infrastructure;
- no hardware-AES boot check is implemented;
- Python cannot guarantee reliable zeroization of immutable plaintext/key buffers;
- hybrid post-quantum wrapping/signatures are not implemented;
- rotation, backup/restore, mass rewrap and disaster-recovery acceptance tests need broader coverage.

Encryption does not protect data before detection, detector misses, compromised authorized KMS identities, raw application logs, endpoints that bypass AirShield or content already sent to an external service.

10. Receipts, evidence and retention

A receipt should answer: which tenant and policy acted, which destination was requested, what entity classes/counts were found, what decision was made, when it occurred, and which content digest the decision covers. It should not reproduce the raw transcript.

The control plane uses tenant-specific sequencing and previous-hash linkage to make deletion or reordering detectable, with external signing through the configured provider. The exporter verifies chain continuity and signatures before producing a private JSONL evidence package and SHA-256 sidecar.

A sidecar is not an immutable anchor. Production evidence must be transferred to independently administered retention-locked storage, with object version/external timestamp recorded. Retention and deletion schedules must address raw transient content, encrypted mappings, session metadata, receipts, model logs, backups and exported evidence separately.

11. Policy, destination authorization and RIA integration

The recommended integration is:

CareShield widget → trusted organization backend → AirShield protect/policy/receipt → RIA orchestrator → token-aware action broker → booking/EHR connector → response protection → widget

Why the organization backend is required

The browser is not trusted with booking credentials, control-plane workload identity, reidentification permissions or arbitrary connector access. The host backend owns authenticated user context and business authorization. It requests AirShield protection and forwards only permitted protected content to the RIA.

What the RIA receives

The RIA receives protected intent such as symptoms and timing with direct identifiers replaced by tokens. It may reason over meaning, ask allowed follow-up questions and propose an action. It should not have generic vault access.

Token-aware action broker

A production booking action cannot simply send [PERSON_X] to an external scheduler. A trusted broker must:

- 1 Validate the final receipt and decision.
- 2 Validate user/session/business authorization and action policy.
- 3 Permit only an allowlisted operation and fields.
- 4 Resolve only the exact token fields needed for that connector.
- 5 Release values directly to the trusted system of record, not back through the model.
- 6 Enforce idempotency, rate, destination, time window and approval requirements.
- 7 Record the action without logging plaintext.

The current CareShield widget demonstrates the protected RIA view and a synthetic reservation. The token-aware broker, real RIA connector and real booking connector are future production work.

11A. EgressSeal product layer

EgressSeal™ turns a protection result into a destination-bound release object. Instead of treating a green UI state as authorization, it binds the protected-content digest, upstream receipt reference, tenant policy, exact destination, ContextFence result, permitted action, issue time, expiry and nonce into one signed envelope. Changing content, destination or action invalidates the authorization.

The hackathon route uses a process-local upstream-receipt registry and Ed25519 key. The registry requires the receipt identifier, protected digest, decision, policy and destination created by `/api/protect` to match before signing. It then supports three operations:

- 1 **Issue:** refuse when upstream decision is not allow, receipt is missing, destination is blocked or ContextFence exceeds the destination threshold.
- 2 **Verify:** validate signature, signing-key identity, expiry and protected-content digest before unlocking downstream behavior.
- 3 **Execute:** verify the seal again, enforce the single policy-derived action, use token references only and produce a signed synthetic action receipt.

Destination Switch

Destination is treated as security context, not a cosmetic dropdown. The same protected payload can be allowed for an organization-private AI, allowed with a narrower threshold for a managed regional RIA, held for a research sandbox or blocked for a public general AI. A switch discards the previous seal because an authorization for one destination must never be replayed to another.

ContextFence

Traditional masking evaluates fields independently. ContextFence addresses the mosaic problem: multiple tokens, entity classes, semantic details, timing, measurements, relationships and long conversations can collectively identify a person even when no direct identifier remains. The demonstration produces an explainable score and destination-specific allow, review or block result.

ContextFence is a policy signal, not a mathematically proven anonymity guarantee. Production thresholds require representative evaluation, attack simulation, utility testing, governance and monitoring.

SafeAction

SafeAction demonstrates a stronger alternative to giving an AI vault access. The model sees and proposes an operation using tokens. A trusted broker verifies the seal and allowlist, then resolves only inside the connector boundary. The action receipt states that raw values were not visible to the model.

The current connector is synthetic and resolves no real identity. Production requires a separately deployed broker, scoped service identity, idempotency store, connector-specific field policy, approval/escalation controls, real system-of-record integration and output protection.

The [™] marks denote product-concept branding, not registered trademark status. The development signer is cryptographically functional but not a production authority; production must use a pinned external KMS/HSM trust anchor and authoritative upstream-receipt verification.

12. CareShield Assistant walkthrough

The user can type or speak a symptom statement. Raw text is shown in a local-only bubble. The server creates a Healthcare policy session and calls AirShield protection. The widget displays the protected outbound version plus decision, entity count and receipt reference. It then shows a synthetic general-physician slot and permits a demo reservation.

Safety boundaries are explicit:

- not emergency care;
- not autonomous diagnosis;
- no clinician is monitoring the widget;
- no real appointment is made;
- no clinical record is created;
- urgent warning signs direct the person to local emergency services.

For production, customer counsel and clinical safety owners must define triage language, emergency routing, accessibility, age/guardian flows, regional emergency references, clinical-content scope, escalation and record handling. AirShield's privacy controls do not replace clinical governance.

13. Threats and control intent

Threat	Control intent	Residual limitation
Raw data sent directly to AI	Route through enforced gateway/control plane	Application can still bypass unless network/policy blocks direct egress
Stolen browser token	Short-lived host auth, origin and session validation	Compromised endpoint remains high risk
Client forges speaker identity	Ignore client trust headers; verify issuer/channel binding	Host issuer or channel provenance can be wrong
Detector miss	Ensemble, fail-closed uncertainty, representative evaluation	No detector achieves perfect recall
Chunk-boundary leakage	Interim not egress-safe; final whole-turn recheck	Latency and buffering must be engineered
Cross-tenant token lookup	Tenant AAD, predicates, composite relationships	Query and migration defects require continual testing
Database theft	Per-record AES-GCM and externally wrapped DEKs	Authorized key-service compromise can enable decrypt
Insider reidentification	Requester/approver separation, purpose, expiry, one-time retrieval	API dual control alone does not eliminate collusion
Prompt injection/tool abuse	Destination/action policy and trusted broker	Comprehensive output/tool controls are not complete

Threat	Control intent	Residual limitation
Evidence tampering	Signed chain and external immutable anchoring	Local chain without independent anchor is insufficient
Model supply-chain attack	Pinned manifests and artifact hashes	Build/release infrastructure must also be trusted
Denial of service	Bounded sizes, rates, sessions and inference concurrency	Capacity/DDoS controls require target-environment testing

14. Deployment for Nordic, EU and US clients

Azure-private reference

The Azure profile is designed around private AKS workloads, PostgreSQL Flexible Server, separate Key Vault responsibilities, Workload Identity, private connectivity, restrictive network policy, signed/pinned images and preloaded models. Customer-specific region selection, policy, quota, logging, backup, key recovery and private DNS must be validated in a live subscription.

Cloud-neutral Kubernetes

The portable profile uses standard Kubernetes controls and OpenBao Transit as the external cryptographic provider. It requires a capable CNI for NetworkPolicy, trustworthy workload identity, certificate automation, secrets/key-service separation, persistent model storage and an independently operated evidence destination.

Regulatory posture

AirShield can support control objectives, but applicability and conformity depend on the customer's role, workflow, data, geography and contracts. Nordic/EU deployments may intersect GDPR, national NIS2 implementations, DORA, the Cyber Resilience Act, EU AI Act and EHDS. US healthcare and payments may implicate HIPAA/BAA and PCI responsibilities. No source-code feature creates certification by itself.

15. Operational production requirements

Before processing real data, the organization must complete:

- representative ASR word-error and critical-entity evaluation by accent, noise, codec, device, sector and speaker overlap;
- detector recall/precision and end-to-end leakage evaluation, including adversarial and long-session cases;
- diarization and channel-binding error evaluation, with explicit unknown thresholds;
- security review, penetration test, threat-model sign-off and privacy/legal assessment;
- KMS/HSM roles, identity separation, key rotation, recovery and mass rewrap exercises;
- PostgreSQL concurrency, tenant isolation, backup, restore, migration and deletion tests;
- certificate, gateway secret, model and signing-key rotation drills;
- complete observability that excludes raw content;
- incident response, rollback, kill switch, retention and subject-rights procedures;
- immutable evidence export, independent anchoring and periodic verification;
- output/TTS DLP and token-aware tool/action broker completion;
- capacity, failover, SLO and cost validation on selected hardware;
- customer contracts, data-processing terms, supplier reviews and regional transfer controls.

16. CEO questions and direct answers

Is AirShield an AI model?

It is primarily a privacy enforcement and evidence layer that uses models as components. The differentiated product is the controlled pre-egress workflow: identity-aware policy, protection, destination authorization, encrypted token mapping, action mediation and proof.

Why not rely on the AI provider's privacy mode?

Provider controls are useful but apply after content reaches that provider. AirShield gives the customer a provider-neutral control point before egress and can route the same protected contract to multiple approved destinations.

Can the AI still be useful after masking?

Often yes. Symptoms, timing, intent, transaction issue and workflow context remain useful while names, numbers and direct identifiers become stable references. Each use case requires utility testing; over-masking can harm outcomes.

Does self-hosting mean free?

No. It replaces usage-priced STT dependency with customer-controlled compute and operations. Costs include hardware, model optimization, patching, scaling, monitoring, evaluation and support.

Does AirShield authenticate a person's voice?

No. Diarization tracks who appears to be speaking relative to other tracks. Identity comes from the host's authentication and trusted isolated-channel binding. Biometric/liveness assurance, if required, is a separate specialist control.

Is AES-256-GCM enough?

It is a strong appropriate AEAD primitive for vault mappings when used correctly, but production security also depends on key custody, workload identity, AAD/versioning, nonce discipline, rotation, recovery, access separation, logs, backups and operational verification.

Can the AI book an appointment safely?

Only through a trusted token-aware action broker that validates receipt, user authorization, action scope and connector policy and resolves minimum fields directly to the system of record. The current widget performs no real booking.

Is the product compliant?

The repository supports control objectives; it is not a legal opinion or certification. Compliance and validation depend on the full customer implementation and independent review.

What is the largest technical risk?

End-to-end leakage risk is dominated by detector/ASR/context error and bypass—not by the AES primitive. Representative evaluation, fail-closed routing, enforced network paths and output/tool controls are therefore essential.

What should be built next?

A production-grade RIA connector and token-aware action broker, complete output/TTS DLP, expanded/versioned vault format, per-tenant key hierarchy, evaluated model release pipeline, immutable evidence service and customer-ready integration SDK/gateway are the highest-value next steps.

17. Product opportunities alongside the core

- **Privacy contract registry:** machine-readable data categories, allowed destinations, actions and retention by tenant.
- **Token-aware action gateway:** safe booking, CRM, claims, payments and ticket operations without revealing values to the model.
- **Output/TTS firewall:** inspect model responses and synthesized speech before release.
- **Evidence verifier portal:** independent receipt, signature, chain and deployment-attestation verification.
- **Model assurance lab:** repeatable leakage, accent, codec, diarization and latency scorecards.
- **Legacy integration fabric:** reverse proxy, sidecar, event-stream and contact-center media adapters.
- **Privacy digital twin:** simulate policy impact and utility loss before deployment.
- **Regional policy packs:** customer-reviewed Nordic/EU and US controls without unsupported certification claims.
- **Incident kill switch:** tenant/destination/model revocation with provable propagation.
- **Privacy-preserving analytics:** aggregate operational metrics designed not to expose protected mappings.

The defensible market position is not “another redactor.” It is a provider-neutral pre-egress control and proof layer that combines voice-first UX, identity-safe speaker binding, reversible tokenization, destination policy and trusted actions across sectors.

18. Recommended phased path

Phase	Outcome	Exit evidence
0. Hackathon proof	Responsive UI, protected transcript, CareShield demonstration	Synthetic demo script and clean build
1. Controlled pilot	One sector, one channel, one AI destination, no autonomous high-risk actions	Representative evaluation, security review, monitored allow/block
2. Action pilot	Token-aware broker for one low-risk reversible operation	Connector threat model, idempotency and action audit
3. Regulated production	Private deployment with external key custody and evidence anchoring	Independent review, DR/rotation tests, operational ownership
4. Platform scale	Multi-sector adapters, policy registry and model assurance service	SLOs, tenant isolation evidence, automated release gates

Executive release rule: useful meaning may leave the boundary only after evaluated protection, destination authorization and verifiable final evidence. Identity resolution and operational actions occur only inside a separately authorized trusted path.